

REPORT PER DIRIGENTE

Sintesi gestionale con evidenze della pratica

Executive Summary

Il Vulnerability Assessment condotto con Nessus sul sistema Metasploitable ha evidenziato un livello di rischio elevato. Sono state individuate vulnerabilità Critical e High legate a sistemi e servizi obsoleti, protocolli legacy e configurazioni non sicure.

Filter	Search Vulnerabilities		70 Vulnerabilities				
Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	
HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	
HIGH	7.5			NFS Shares World Readable	RPC	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	28	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	

Situazione iniziale della scansione Nessus.

Indicatori principali

Indicatore	Risultato
Vulnerabilità iniziali	70
Vulnerabilità post-remediation	58
Riduzione	12 (~17,1%)
Target	192.168.60.101

--	--

Principali rischi

- Bind shell con evidenza di esecuzione come root.
- VNC con credenziale debole.
- Ubuntu 8.04 fuori supporto.
- Tomcat 5.5 fuori supporto e vulnerabilità AJP/Ghostcat.
- Protocolli SSL legacy.

Impatto e priorità

Priorità	Decisione proposta
Critica	Rimuovere backdoor/bind shell e correggere accessi remoti deboli
Critica	Aggiornare OS e Tomcat
Alta	Disabilitare SSLv2/SSLv3
Alta	Ripetere la scansione e verificare la chiusura dei finding

REPORT TECNICO

Vulnerability Assessment con Nessus – Metasploitable

Obiettivo e perimetro

L'attività consiste in un Vulnerability Assessment sulla macchina Metasploitable, eseguito con Nessus in ambiente di laboratorio. Il target utilizzato nella pratica è 192.168.60.101. La scansione è stata effettuata con la policy Basic Network Scan.

Scansione e risultato iniziale

La scansione iniziale ha evidenziato una superficie di rischio ampia, con numerose vulnerabilità Critical, High e Medium.

Filter	Search Vulnerabilities		70 Vulnerabilities				
Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
☐ CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
☐ CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
☐ CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
☐ MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
☐ CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
☐ HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	
☐ HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	
☐ HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	
☐ HIGH	7.5			NFS Shares World Readable	RPC	1	
☐ MIXED	...	...	...	SSL (Multiple Issues)	General	28	
☐ MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
☐ MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
☐ MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	

Risultato della scansione Nessus e panoramica delle vulnerabilità rilevate.

Parametro	Valore
Target	192.168.60.101
Policy	Basic Network Scan
Vulnerabilità iniziali	70
Scanner	Local Scanner

Vulnerabilità analizzate

Finding	Severità	CVSS	Porta/servizio	Remediation sintetica
Canonical	Critical	10.0	80/tcp	Aggiornare a OS

Ubuntu Linux SEoL (8.04.x)				supportato
VNC Server 'password' Password	Critical	10.0	5900/tcp	Password forte / eliminare default
SSL Version 2 and 3	Critical	9.8	25/tcp, 5432/tcp	Disabilitare SSLv2/SSLv3
Bind Shell Backdoor Detection	Critical	9.8	1524/tcp	Rimuovere bind shell e verificare integrità
Apache Tomcat SEoL (<=5.5.x)	Critical	10.0	8180/tcp	Aggiornare Tomcat
Tomcat AJP Request Injection (Ghostcat)	Critical	9.8	8009/tcp	Aggiornare e proteggere/disabilitare AJP

Evidenze Nessus

The screenshot displays the Nessus interface for a vulnerability titled "VNC Server 'password' Password". The severity is marked as "CRITICAL".

Description: The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Solution: Secure the VNC service with a strong password.

Output: Nessus logged in using a password of "password". To see debug logs, please visit individual host.

Port	Hosts
5900 / tcp / vnc	192.168.60.101

Plugin Details:

- Severity: Critical
- ID: 61708
- Version: \$Revision: 1.2 \$
- Type: remote
- Family: Gain a shell remotely
- Published: August 29, 2012
- Modified: September 24, 2015

Risk Information:

- Risk Factor: Critical
- CVSS v2.0 Base Score: 10.0
- CVSS v2.0 Vector: CVSS2#A#N/A/C/L/Au#N/C:C/C:C/A/C

Vulnerability Information:

- Default Account: true
- Exploited by Nessus: true

Nessus: Ubuntu 8.04 identificato come sistema operativo fuori supporto.

Metasploitable scanzioni completa / Plugin #201352

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 70 Remediations 2 Notes 2 History 3

CRITICAL Canonical Ubuntu Linux SEoL (8.04.x)

Description
According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.
Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Solution
Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

See Also
<http://www.nessus.org/u/73bdb2d2e>

Output

```
OS : Ubuntu Linux 8.04
Security End of Life : May 9, 2013
Time since Security End of Life (Est.) : >= 13 years
```

To see debug logs, please visit individual host

Port	Hosts
80 / tcp / www	192.168.80.101

Plugin Details

Severity: Critical
ID: 201352
Version: 1.2
Type: combined
Family: General
Published: July 3, 2024
Modified: March 26, 2025

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 10.0
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/CH:H/IA:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/RC:A/C

Vulnerability Information

CPE: cpe:/o:canonical:ubuntu_linux
Unsupported by vendor: true

Nessus VNC sulla porta 5900/tcp con password debole 'password'.

Hosts 1 Vulnerabilities 78 Remediations 2 Notes 2 History 3

CRITICAL SSL Version 2 and 3 Protocol Detection

Description
The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:
- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.
An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.
Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.
NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of "strong cryptography".

Solution
Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

See Also
<https://www.schneier.com/academic/papers/files/paper-ssl.pdf>
<http://www.nessus.org/u/b06c7e95>
<http://www.nessus.org/u/247c4540>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<http://www.nessus.org/u/56f5ba7b>

Plugin Details

Severity: Critical
ID: 20007
Version: 1.35
Type: remote
Family: Service detection
Published: October 12, 2005
Modified: April 13, 2026

Risk Information

Risk Factor: Critical
CVSS v3.0 Base Score: 9.8
CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:L/CH:H/IA:H
CVSS v2.0 Base Score: 10.0
CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/RC:A/C

Vulnerability Information

In the news: true

Nessus Bind Shell Backdoor sulla porta 1524/tcp; l'output mostra uid=0(root).

Output

```
Nessus was able to exploit the issue using the following request :
0x0000: 02 02 00 08 48 54 54 50 2F 11 2E 11 00 00 0F 2F ...HTTP/1.1.../
0x0010: 61 73 64 66 2F 78 78 78 78 2E 6A 73 70 00 00 aad7/xxxxx.jpg..
0x0020: 09 4C 4F 63 61 6C 68 6F 73 74 00 FF FF 00 09 4C localhost....l
0x0030: 4F 63 61 6C 68 6F 73 74 00 00 00 00 09 40 96 ocalhost...P...
0x0040: 00 0A 68 65 65 70 2D 61 6C 69 76 65 00 0F 61 ..keep-alive...A
0x0050: 63 63 65 70 74 2D 4C 61 68 6F 75 61 67 65 00 00 cept-Language..
0x0060: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0070: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0080: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0090: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x00F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0100: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0110: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0120: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0130: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0140: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0150: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0160: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0170: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0180: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0190: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x01F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0200: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0210: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0220: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0230: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0240: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0250: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0260: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0270: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0280: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0290: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x02F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0300: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0310: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0320: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0330: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0340: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0350: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0360: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0370: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0380: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0390: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x03F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0400: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0410: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0420: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0430: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0440: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0450: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0460: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0470: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0480: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0490: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x04F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0500: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0510: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0520: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0530: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0540: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0550: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0560: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0570: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0580: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0590: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x05F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0600: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0610: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0620: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0630: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0640: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0650: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0660: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0670: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0680: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0690: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x06F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0700: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0710: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0720: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0730: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0740: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0750: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0760: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0770: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0780: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0790: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x07F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0800: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0810: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0820: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0830: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0840: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0850: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0860: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0870: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0880: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0890: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x08F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0900: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0910: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0920: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0930: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0940: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0950: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0960: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0970: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0980: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0990: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09A0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09B0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09C0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09D0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09E0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x09F0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A00: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A10: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A20: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A30: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A40: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A50: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A60: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A70: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A80: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0A90: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AA0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AB0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AC0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AD0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AE0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0AF0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B00: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B10: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B20: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B30: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B40: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B50: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B60: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B70: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B80: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0B90: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0BA0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0BB0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0BC0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
0x0BD0: 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 ...
```

Nessus Apache Tomcat 5.5 identificato come componente fuori supporto.

The screenshot shows the Nessus interface for a vulnerability titled 'Bind Shell Backdoor Detection'. The severity is 'CRITICAL'. The description states: 'A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.' The solution suggests: 'Verify if the remote host has been compromised, and reinstall the system if necessary.' The output shows a successful execution of the 'id' command, resulting in root access. The plugin details on the right indicate a severity of 'Critical', ID '51988', version '1.10', type 'remote', family 'Backdoors', published 'February 15, 2011', and modified 'April 11, 2022'. The risk information shows a 'Risk Factor: Critical' and a 'CVSS v3.0 Base Score: 9.8'.

Nessus Apache Tomcat AJP Connector Request Injection (Ghostcat),
porta 8009/tcp.

Remediation VNC eseguita

La parte pratica di remediation ha riguardato il servizio VNC. Sono stati eseguiti controlli sul processo Xtightvnc, sul file di password VNC e sui permessi della directory ~/.vnc; successivamente il servizio xinetd è stato riavviato e la porta 5900/tcp è stata verificata nuovamente.

```
msfadmin@metasploitable:~$ sudo kill -HUP 4436
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
msfadmin@metasploitable:~$
```

Verifica del processo Xtightvnc e della configurazione VNC.

```
msfadmin@metasploitable:~$ sudo -u msfadmin /usr/bin/vncpasswd /home/msfadmin/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
Cannot write password file /home/msfadmin/.vnc/passwd
msfadmin@metasploitable:~$
```

Verifica del file ~/.vnc/passwd e dei relativi permessi.

```
msfadmin@metasploitable:~$ sudo ls -la /home/msfadmin/.vnc/
total 68
drwx----- 2 root    root    4096 2026-10-03 10:54 .
drwxr-xr-x  9 msfadmin msfadmin 4096 2026-10-03 10:54 ..
-rw-r--r--  1 root    root   34723 2026-10-03 17:40 metasploitable:0.log
-rw-r--r--  1 root    root     5 2026-10-03 10:54 metasploitable:0.pid
-rw-r--r--  1 root    root   8114 2026-10-03 10:23 metasploitable:1.log
-rw-r--r--  1 root    root     5 2026-10-03 10:23 metasploitable:1.pid
-rw-----  1 root    root     8 2026-10-02 16:38 passwd
-rwxr-xr-x  1 root    root    151 2026-10-02 16:38 xstartup
msfadmin@metasploitable:~$
```

Correzione dei permessi/ownership e riavvio di xinetd.

Hosts1Vulnerabilities58Remediations3Notes1History4

Filter

Search Vulnerabilities

58 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count		
CRITICAL	10.0 *	7.9	0.8353	UnrealIRCd Backdoor Detection	Backdoors	1		
CRITICAL	10.0 *	5.8	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1		
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1		
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4		
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1		
HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1		
HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1		
HIGH	7.5			NFS Shares World Readable	RPC	1		
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5		
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1		
MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6		
MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5		

Scan Details

Policy:

Status:

Severity Base:

Scanner:

Start:

End:

Elapsed:

Basic Network Scan

Completed

CVSS v3.0

Local Scanner

Today at 9:30 AM

Today at 9:50 AM

20 minutes

Vulnerabilities

Critical

High

Medium

Low

Info

Verifica finale: il servizio VNC risulta nuovamente in ascolto sulla porta 5900/tcp.

Nota: il riavvio e la verifica della porta confermano che il servizio è attivo; la validazione definitiva della vulnerabilità deve essere effettuata tramite una nuova scansione Nessus.

Scansione post-remediation

Il numero complessivo è passato da 70 a 58 finding, con una riduzione di 12 finding (circa 17,1%). Il risultato dimostra un miglioramento, ma non la risoluzione completa della superficie di rischio.

Raccomandazioni

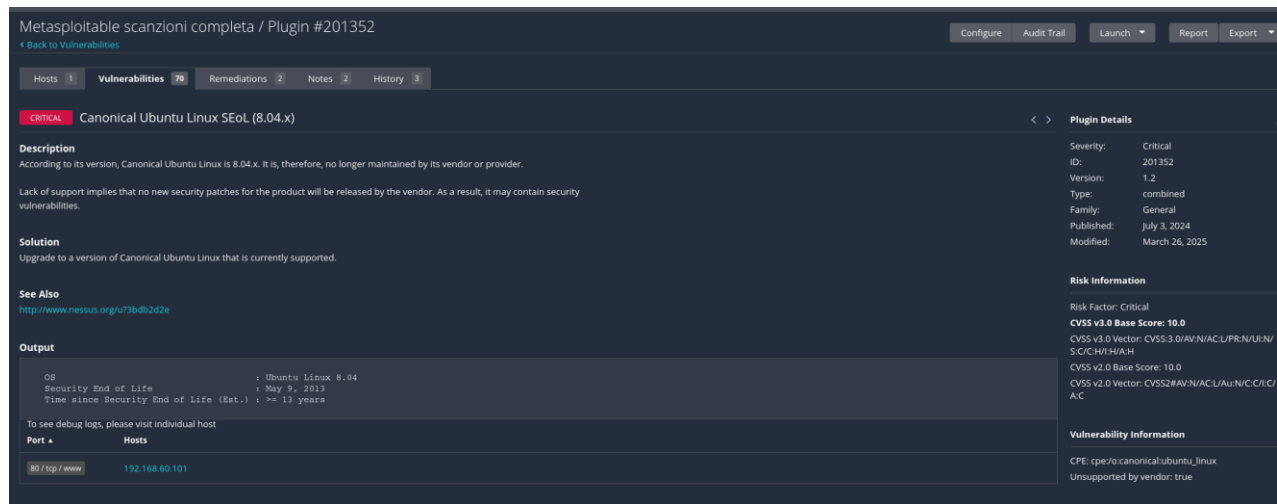
- Aggiornare il sistema operativo fuori supporto.
- Aggiornare Apache Tomcat e mettere in sicurezza il connettore AJP.
- Eliminare la bind shell e verificare l'integrità del sistema.
- Disabilitare SSLv2/SSLv3 e utilizzare TLS moderno.
- Gestire VNC con credenziali robuste e limitare l'esposizione del servizio.
- Ripetere Nessus dopo ogni remediation significativa.

Scopo

Questo documento approfondisce le vulnerabilità più significative rilevate durante la pratica, collegando evidenza Nessus, rischio e remediation.

VNC – credenziale debole

Plugin 61708 – Critical – CVSS 10.0. Nessus ha rilevato il servizio VNC sulla porta 5900/tcp e ha confermato l'utilizzo della password 'password'.

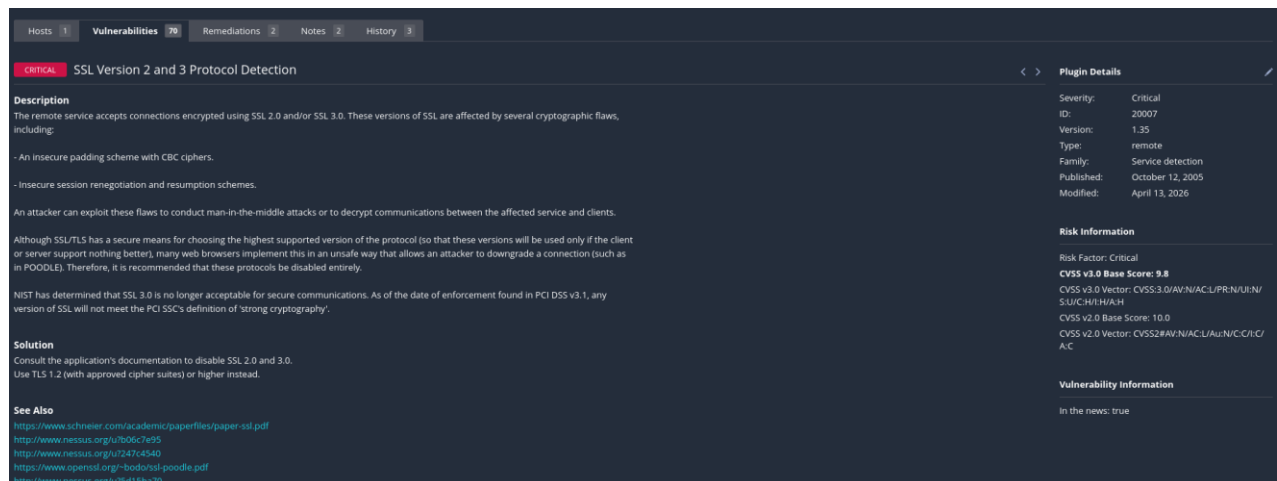


Evidenza Nessus del problema VNC.

Rischio un attaccante remoto potrebbe autenticarsi al servizio e ottenere controllo della sessione grafica. Remediation: utilizzare credenziali robuste, eliminare password predefinite e limitare l'esposizione del servizio.

Bind Shell Backdoor

Plugin 51988 – Critical – CVSS 9.8. Il servizio sulla porta 1524/tcp ha consentito a Nessus di eseguire 'id', restituendo uid=0(root).



Evidenza Nessus della bind shell e dell'output uid=0(root).

Rischio: esecuzione remota di comandi con privilegi elevati.

Remediation: rimuovere/disabilitare il servizio, verificare l'integrità del

sistema e, se necessario, reinstallare il sistema in caso di compromissione.

SSLv2 / SSLv3

Plugin 20007 – Critical – CVSS 9.8. Sono stati rilevati protocolli SSL legacy e cipher deboli. Devono essere disabilitati SSLv2 e SSLv3; deve essere utilizzato TLS 1.2 o superiore. **Apache Tomcat / Ghostcat**

The screenshot shows a Nessus scan output for a vulnerability. The main text area displays a hex dump of a request and a table of hosts. The hosts table has two columns: 'Port' and 'Hosts'. The first row shows '8099/http/ajp13' and '192.168.60.101'. To the right, a 'Vulnerability Information' section provides details: CPE: cpe:/a:apache:tomcat, Exploit Available: true, Exploit Ease: Exploits are available, Patch Pub Date: March 1, 2020, Vulnerability Pub Date: March 1, 2020, Exploited by Nessus: true. A 'Reference Information' section lists CEA-ID: CEA-2020-0021, CSA-KNOWN-EXPLOITED: 2022/03/17, and CVE: CVE-2020-1745, CVE-2020-1938.

Port	Hosts
8099/http/ajp13	192.168.60.101

Tomcat 5.5 fuori supporto.

The screenshot shows a Nessus scan output for a vulnerability. The main text area displays a hex dump of a request and a table of hosts. The hosts table has two columns: 'Port' and 'Hosts'. The first row shows '1524/http/wild_wmef' and '192.168.60.101'. To the right, a 'Vulnerability Information' section provides details: CPE: cpe:/a:apache:tomcat, Exploit Available: true, Exploit Ease: Exploits are available, Patch Pub Date: March 1, 2020, Vulnerability Pub Date: March 1, 2020, Exploited by Nessus: true. A 'Reference Information' section lists CEA-ID: CEA-2020-0021, CSA-KNOWN-EXPLOITED: 2022/03/17, and CVE: CVE-2020-1745, CVE-2020-1938.

Port	Hosts
1524/http/wild_wmef	192.168.60.101

Vulnerabilità AJP Request Injection (Ghostcat).

Il Tomcat 5.5 rilevato è fuori supporto. La vulnerabilità Ghostcat riguarda il connettore AJP e può consentire lettura di file e, in determinate condizioni, esecuzione di codice. La remediation consiste

nell'aggiornamento a una versione supportata e nella messa in sicurezza/disabilitazione di AJP quando non necessario.

Evidenze della remediation VNC

```
msfadmin@metasploitable:~$ sudo kill -HUP 4436
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
msfadmin@metasploitable:~$
```

Processo Xtightvnc in esecuzione.

```
msfadmin@metasploitable:~$ sudo -u msfadmin /usr/bin/vncpasswd /home/msfadmin/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
Cannot write password file /home/msfadmin/.vnc/passwd
msfadmin@metasploitable:~$
```

Controllo del file di password VNC.

```
msfadmin@metasploitable:~$ sudo ls -la /home/msfadmin/.vnc/
total 68
drwx----- 2 root      root      4096 2026-10-03 10:54 .
drwxr-xr-x  9 msfadmin msfadmin  4096 2026-10-03 10:54 ..
-rw-r--r--  1 root      root     34723 2026-10-03 17:40 metasploitable:0.log
-rw-r--r--  1 root      root         5 2026-10-03 10:54 metasploitable:0.pid
-rw-r--r--  1 root      root     8114 2026-10-03 10:23 metasploitable:1.log
-rw-r--r--  1 root      root         5 2026-10-03 10:23 metasploitable:1.pid
-rw-----  1 root      root         8 2026-10-02 16:38 passwd
-rwxr-xr-x  1 root      root      151 2026-10-02 16:38 xstartup
msfadmin@metasploitable:~$
```

Riavvio di xinetd dopo la modifica.

The screenshot displays the VulnHub interface with a table of vulnerabilities and a summary of scan details on the right.

Sev	CVSS	VPR	EPSS	Name	Family	Count	Actions
CRITICAL	10.0 *	7.9	0.8353	UnrealIRCd Backdoor Detection	Backdoors	1	🔍 ✎
CRITICAL	10.0 *	5.8	0.7072	Debian OpenSSH/OpenSSL Package Random Number Generator Weakness	Gain a shell remotely	1	🔍 ✎
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	🔍 ✎
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	🔍 ✎
HIGH	7.5	4.9	0.3693	Samba Badlock Vulnerability	General	1	🔍 ✎
HIGH	7.5 *	4.9	0.119	rlogin Service Detection	Service detection	1	🔍 ✎
HIGH	7.5 *	4.9	0.119	rsh Service Detection	Service detection	1	🔍 ✎
HIGH	7.5			NFS Shares World Readable	RPC	1	🔍 ✎
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	🔍 ✎
MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1	🔍 ✎
MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6	🔍 ✎
MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	5	🔍 ✎

Scan Details

- Policy: Basic Network Scan
- Status: Completed
- Severity Base: CVSS v3.0
- Scanner: Local Scanner
- Start: Today at 9:30 AM
- End: Today at 9:50 AM
- Elapsed: 20 minutes

Vulnerabilities

- Critical (Red)
- High (Orange)
- Medium (Yellow)
- Low (Green)
- Info (Blue)

Verifica della porta 5900/tcp.

Metodo di verifica

Per ogni remediation si deve identificare il servizio, applicare la correzione, riavviare il servizio interessato, verificare localmente processi e porte e quindi ripetere la scansione Nessus.

L'esercizio ha permesso di completare il ciclo vulnerability assessment → analisi → remediation → verifica. Le vulnerabilità Critical devono avere priorità assoluta in un eventuale ambiente produttivo.

Conclusione gestionale

La remediation effettuata ha prodotto un miglioramento misurabile. Tuttavia, le 58 vulnerabilità residue indicano che il sistema necessita di ulteriori interventi prima di poter essere considerato adeguatamente protetto. Si raccomanda di completare il ciclo remediation e verifica.